

Fondamentaux

Programme

01 Panorama de la cybersécurité

02 Principes fondamentaux

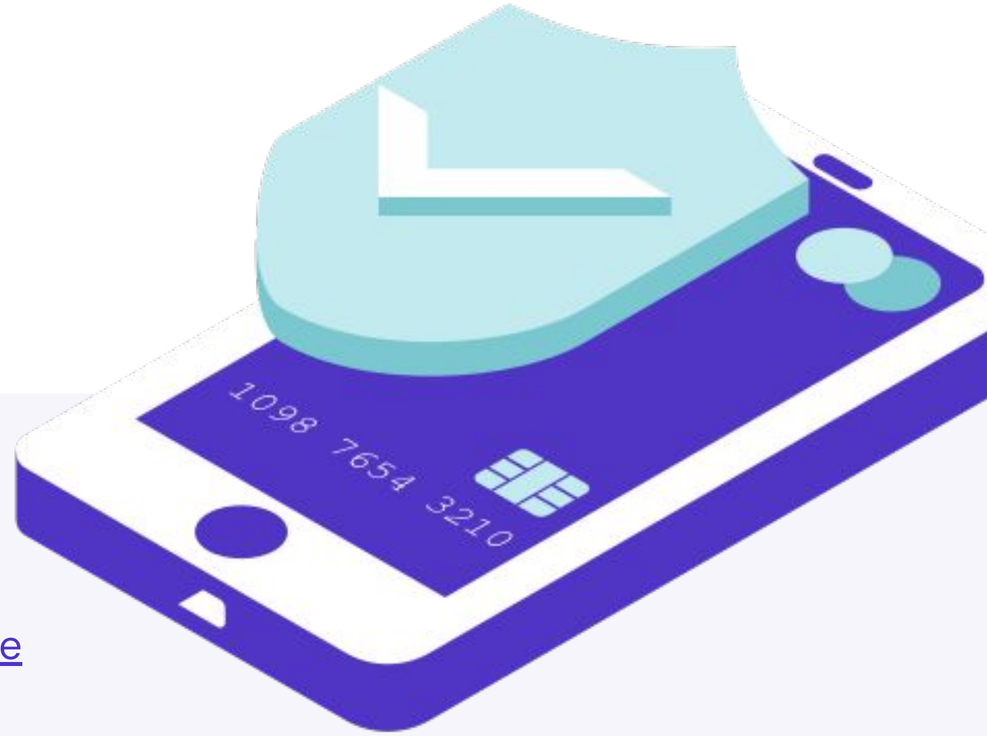
03 Les cyberattaques

04 Le facteur humain



PARTIE 1 · PANORAMA

C’est quoi la cybersécurité ?



La cybersécurité est la capacité protéger les systèmes d'information contre les atteintes à leur disponibilité, leur intégrité ou leur confidentialité.

Pourquoi la cybersécurité est un enjeu majeur ?



La numérisation croissante de l'économie rend chaque organisation dépendante de ses systèmes d'information. Un incident peut toucher la continuité d'activité, la réputation, et parfois la sécurité physique des personnes.

3 cyberattaques marquantes qui ont profondément marqué l'histoire de la cybersécurité par leur ampleur, leurs techniques ou leurs conséquences mondiales

01 WannaCry (2017)

-WannaCry est sans doute l'attaque par rançongiciel (ransomware) la plus célèbre de l'histoire. En quelques heures, elle a infecté plus de 300 000 ordinateurs dans 150 pays.
-A fortement perturbé le système de santé britannique (NHS) : rendez-vous annulés, services déviés.

02 L'attaque contre l'ANTS (Avril 2026)

-La faille exploitée serait de type IDOR : il suffisait de modifier un identifiant dans une requête pour accéder aux données d'un autre utilisateur, sans aucun contrôle.
-Fuite de 19 millions d'enregistrements de la base de données

03 TV5 Monde (2015)

Le 8 avril 2015, TV5 MONDE a été victime d’une attaque informatique mettant en panne l’ensemble de ses réseaux et l’empêchant de diffuser ses programmes. C’était la première fois qu’un cyber-sabotage était commis sur le sol français

Les principaux métiers de cybersécurité par spécialité

01 Stratégie et Gouvernance

- Le RSSI (Responsable de la Sécurité des Systèmes d'Information) définit la politique de sécurité.
- Le DPO (Data Protection Officer) assure la conformité RGPD.
- Le Risk Manager évalue les menaces pesant sur l'organisation.

02 Opérations et Défense “Blue Team”

- L'analyste SOC surveille les alertes en temps réel et répond aux incidents.
- L'ingénieur sécurité déploie les solutions techniques (pare-feux, IDS, chiffrement).

03 Offensif et Audit (Red Team, Pentester)

- Le Pentester réalise des tests d'intrusion pour découvrir les failles avant qu'elles ne soient exploitées.
- L'auditeur sécurité vérifie que les systèmes respectent les normes en vigueur.

Référentiels & Standards : Les piliers de la cybersécurité

01 ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information) : agence française de référence en cybersécurité. Publie des guides pratiques (dont le guide d'hygiène informatique), délivre des visas de sécurité et qualifie des prestataires.

02 Cadre Réglementaire : Le RGPD pour la protection des données personnelles

03 ISO/IEC 27001 : norme internationale de management de la sécurité de l'information (SMSI), qui permet à une organisation de faire certifier sa démarche de sécurité.



PARTIE 2 · PRINCIPES

Principes

Les 7 piliers de la sécurité de l'information

La sécurité de l'information repose sur un socle de sept principes. Les trois premiers (DIC) sont les plus connus

01 **Disponibilité:**

Le système ou la donnée est accessible par les personnes autorisées quand elles en ont besoin

02 **Intégrité:**

La donnée n'est pas altérée, volontairement ou non, sans autorisation

03 **Confidentialité:**

Seules les personnes autorisées accèdent à l'information

04 **Authentification:**

Vérifier l'identité d'un utilisateur avant de lui donner accès

05 **Traçabilité:**

Pouvoir retracer qui a fait quoi et quand

06 **Non-répudiation:**

Empêcher un auteur de nier une action qu'il a réellement réalisée

07 **Autorisation:**

Déterminer ce qu'un utilisateur authentifié a le droit de faire

Trois exemples concrets tirés du quotidien d'un consultant en cybersécurité



AUTHENTIFICATION

Un technicien saisit un identifiant et un mot de passe avant d'accéder à SRV-AD01 : c'est la vérification de son identité.



TRAÇABILITÉ

Le journal de connexion de SRV-AD01 permet de savoir qui s'est connecté, quand, et avec quel résultat.



NON-RÉPUDIATION

Une signature numérique appliquée à un document empêche son auteur de nier l'avoir signé ensuite.

Exercice

Pour chacune des situations suivantes chez ARCADIA, identifier le principe fondamental principalement en jeu :

01 Un technicien consulte les journaux de connexion pour savoir qui a modifié un fichier partagé.

02 Un onduleur de secours permet au serveur de continuer à fonctionner lors d'une coupure de courant.

03 Un stagiaire n'a accès qu'en lecture seule au dossier des tournées de livraison.



PARTIE 3 · Les attaques

Principales attaques de cybersécurité

01 **Malware**

Terme générique pour tout logiciel conçu pour nuire à un système (virus, vers, chevaux de Troie et logiciels espions)

02 **Phishing (Ingénierie sociale)**

Tromper une victime par courriel frauduleux (phishing) ou par SMS (smishing)afin de permettre un accès non autorisé à des systèmes ou services

03 **Rançongiciel (Ransomware)**

Malware qui chiffre les données et exige une rançon pour les débloquer

04 **Man-in-the-Middle" (MITM)**

Un attaquant intercepte les communications entre deux parties afin d'espionner, modifier ou voler les informations échangées.

05 **Attaque par force brute**

Consiste à tester automatiquement un grand nombre de combinaisons de mots de passe jusqu'à trouver la bonne.

06 **DoS : Déni de service**

Surcharger l’infrastructure réseau afin de rendre un système indisponible.

07 **Exploitation de vulnérabilités (Zero-day)**

Les cybercriminels exploitent une faille de sécurité inconnue ou non corrigée avant que l'éditeur ne publie un correctif.

08 **Credential Stuffing**

Essai d'un même mot de passe courant sur un grand nombre de comptes



PARTIE 4 · FACTEUR HUMAIN

Pourquoi l'humain est-il la première faille ?

L'humain est souvent qualifié de « première faille de sécurité » (ou « maillon faible ») non pas par manque d'intelligence, mais parce qu'il constitue une variable imprévisible dans un système qui, lui, est conçu pour être logique et prévisible.

Voici pourquoi l'aspect humain reste au cœur des vulnérabilités, malgré l'évolution des outils de défense :

- Autorité : se faire passer pour un supérieur hiérarchique, un service officiel ou le support informatique.
- Urgence : créer une pression temporelle qui empêche la vérification (« action requise dans l'heure »).
- Confiance : usurper l'identité d'un contact connu de la victime (collègue, fournisseur habituel).
- Curiosité ou appât du gain : promesse de gain, de colis à réceptionner, de remboursement.

Études de cas

01 Faux SMS (smishing):

“Votre colis est en attente, réglez 2,00 € de frais de douane avant 18h : [lien] “.

- Signal d'alerte : lien raccourci ou domaine inhabituel, urgence artificielle.
- Bon réflexe : ne jamais cliquer ; consulter le site officiel du transporteur directement via son adresse connue.

02 Faux appel « support Microsoft »

Un interlocuteur téléphonique affirme que l'ordinateur de la victime est infecté, demande l'installation d'un logiciel de prise en main à distance ou l'achat d'un « pack de support ».

- Signal d'alerte : Microsoft n'appelle jamais spontanément un particulier ou une entreprise pour signaler une infection.
- Bon réflexe : raccrocher, ne jamais installer de logiciel à la demande d'un appel non sollicité.

03 QR code frauduleux (« quishing »)

Un autocollant portant un QR code piégé est apposé sur une affiche, un horodateur ou un support légitime, redirigeant vers un site de phishing une fois scanné.

- Signal d'alerte : autocollant qui semble rajouté, QR code isolé sans autre moyen de paiement/accès proposé.
- Bon réflexe : vérifier l'URL affichée après le scan avant de saisir la moindre information ; privilégier une saisie manuelle de l'adresse connue.



Quel est le point commun entre ces arnaques ?

Dans les trois cas, la victime n'a pas eu le temps ou le réflexe de vérifier par un second canal avant d'agir. C'est précisément ce réflexe que cette formation cherche à ancrer.

Avez-vous des questions ?